



Cyber Security Internship Task 07 Report

Submitted By:	
Name:	Muhammad Ahmad
Registration No.:	16112053
Domain:	Cyber Security
Supervisor:	Salman Fazal
Date:	10-07-2026

Table of Contents

Part 1 & 2: Cyber Kill Chain, MITRE ATT&CK, and TTP Mapping	3
Part 3: Forensic Acquisition Strategy & Order of Volatility (OOV)	5
1. Order of Volatility (OOV) — Sequence of Evidence Collection	6
2. Forensic Acquisition Strategy (Evidence Collection Plan)	8
Sigma Rules and YARA Rule Development	11
Sigma Rule.....	11
YARA Rule	11
Threat Hunting Using Splunk SPL and Azure Sentinel KQL	24
1. Privilege Escalation (UAC Bypass Detection)	24
Host-Based and Network-Based Indicators of Compromise (IoCs) with Detection Methodology	27
1. Host-Based IoCs and Detection Methodology	28
2. Network-Based IoCs and Detection Methodology	28
Containment, Eradication, Recovery, and Enterprise Hardening (Based on NIST SP 800-61 Rev. 2).....	29
1. Containment.....	30
2. Eradication	31
3. Recovery	32
4. Enterprise Hardening	32

Part 1 & 2: Cyber Kill Chain, MITRE ATT&CK, and TTP Mapping

When an attacker gains access to a network and eventually deploys ransomware, they typically follow a structured attack process. We can map this attack using the **Lockheed Martin Cyber Kill Chain**, which describes the stages of an attack, and the **MITRE ATT&CK Matrix**, which identifies the specific tactics, techniques, and procedures (TTPs) used by the attacker.

Based on the given scenario, the attack can be mapped as follows:

Attack Stage (Cyber Kill Chain)	Attacker Activity (Scenario)	MITRE ATT&CK Technique / TTP	Technical Justification (For Viva)
1. Reconnaissance	Preparing a spear-phishing campaign	T1598 – Phishing for Information	The attacker gathers information about the target organization, such as employee email addresses, organizational structure, and other publicly available details to prepare a targeted phishing attack.
2. Weaponization	Creating a malicious attachment or link	T1204.002 – Malicious File	The attacker prepares a malicious file, such as a shortcut (.lnk), macro-enabled document, or malware payload, to be delivered to the victim.
3. Delivery	Sending a spear-phishing email	T1566.001 – Spearphishing Attachment	The attacker delivers the malicious attachment through a carefully crafted phishing

			email to gain initial access to the target network.
4. Exploitation	The user opens the malicious file, resulting in initial access	T1204.002 – User Execution	When the user opens the malicious attachment, the embedded exploit or script executes, allowing the attacker to compromise the system.
5. Installation (Persistence)	Establishing persistence on the compromised system	T1547.001 – Registry Run Keys / Startup Folder	The attacker creates Registry Run Keys or Scheduled Tasks so that the malware automatically executes whenever the system restarts, ensuring persistent access.
6. Privilege Escalation	Obtaining administrative privileges	T1068 – Exploitation for Privilege Escalation	The attacker exploits a local vulnerability or bypasses User Account Control (UAC) to elevate privileges from a standard user account to Administrator or SYSTEM level.
7. Credential Dumping	Stealing passwords and password hashes	T1003.001 – LSASS Memory	The attacker uses tools such as Mimikatz to extract NTLM password hashes or clear-text credentials from the Windows LSASS process.

8. Lateral Movement	Moving across the Active Directory environment	T1021.002 – SMB/Windows Admin Shares	After compromising one machine, the attacker moves laterally to other systems using SMB, PsExec, or Remote Desktop Protocol (RDP).
9. Data Exfiltration	Uploading sensitive data to cloud storage	T1567.002 – Exfiltration to Cloud Storage	The attacker uses tools such as Rclone to upload stolen data to cloud storage services like Mega, Dropbox, or Amazon S3 before launching ransomware.
10. Impact	Deploying ransomware and deleting system logs	T1486 – Data Encrypted for Impact and T1070.001 – Clear Windows Event Logs	The attacker encrypts the victim's files to disrupt business operations and then clears Windows Event Logs (e.g., using <code>wevtutil cl</code>) to remove forensic evidence and hinder incident investigation.

Part 3: Forensic Acquisition Strategy & Order of Volatility (OOV)

This section focuses on one of the most critical aspects of a digital forensic investigation:

The Forensic Acquisition Strategy and the Order of Volatility (OOV).

When an incident is discovered and there is evidence that an attacker has attempted to delete logs or cover their tracks, investigators **must not immediately shut down or restart the compromised system**. Doing so would permanently destroy valuable volatile evidence stored in memory, including active processes, network connections, encryption keys, and attacker artifacts.

To prevent the loss of critical evidence, investigators follow the **Order of Volatility (OOV)** as defined in **RFC 3227**. This principle states that investigators should collect the **most volatile data first**, followed by less volatile data.

1. Order of Volatility (OOV) — Sequence of Evidence Collection

Evidence should be collected in the following order:

Highest Volatility → Lowest Volatility

**CPU Registers & Cache → RAM (Memory) → Network State → Disk Storage →
Archived Logs & Backups**

CPU Registers and Cache

These are the most volatile components of a computer system and can disappear within nanoseconds. Although they contain valuable execution information, they are typically captured only during specialized debugging or advanced forensic investigations.

System Memory (RAM) Highest Priority

RAM must be acquired before any other evidence because all of its contents are lost when the system is powered off.

RAM may contain:

- Active attacker sessions
- Running processes and commands

- Network connections
- Decrypted credentials obtained by tools such as **Mimikatz**
- Unencrypted ransomware encryption keys
- Malware loaded only in memory

Network State

The next priority is to capture the system's current network activity, including:

- Active TCP and UDP connections
- Open ports
- Routing tables
- Active network sessions

This information helps investigators identify communication between the compromised system and the attacker's infrastructure.

Disk Storage (Non-Volatile Data)

After collecting volatile evidence, investigators create a **forensic bit-by-bit image** of the hard drive. This preserves:

- Files and folders
- Executable programs
- System configuration
- Master File Table (MFT)
- Deleted files and other recoverable artifacts

Archived Logs and Backups

Finally, investigators collect logs that have already been transferred to external systems such as SIEM platforms (e.g., Splunk or ELK Stack) and backup servers. Since these sources remain

intact even if the compromised machine is shut down, they are considered the least volatile evidence.

2. Forensic Acquisition Strategy (Evidence Collection Plan)

The following three steps strategy can be used to collect the evidence

Step 1: Live Memory Acquisition (RAM Capture)

Tool:

- FTK Imager Lite
- Belkasoft RAM Capturer

These portable forensic tools can be executed directly from a USB drive, minimizing changes to the target system.

Action:

- Connect the USB drive.
 - Capture the contents of system memory.
 - Save the memory image as a file such as **memdump.raw**.
-

Step 2: Volatile Network and Process Triage

Immediately after capturing RAM, investigators collect information about the system's current network activity and running processes.

Commands:

```
netstat -ano
```


Purpose:

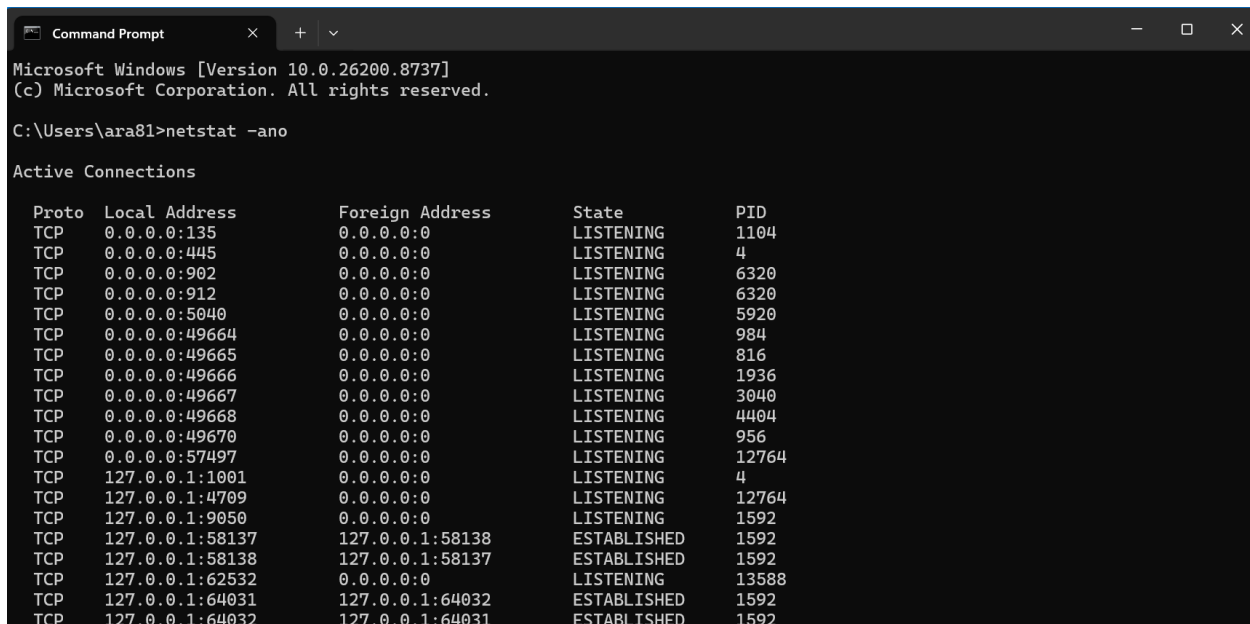
Displays active network connections, listening ports, and associated Process IDs (PIDs), helping identify attacker communication.

```
tasklist /v
```

Purpose:

Lists all running processes with detailed information, including process names, memory usage, and execution status.

The output of these commands should be saved as text files for later forensic analysis.



```
Microsoft Windows [Version 10.0.26200.8737]
(c) Microsoft Corporation. All rights reserved.

C:\Users\ara81>netstat -ano

Active Connections

 Proto Local Address           Foreign Address         State       PID
----
TCP   0.0.0.0:135              0.0.0.0:0               LISTENING   1104
TCP   0.0.0.0:445              0.0.0.0:0               LISTENING   4
TCP   0.0.0.0:902              0.0.0.0:0               LISTENING   6320
TCP   0.0.0.0:912              0.0.0.0:0               LISTENING   6320
TCP   0.0.0.0:5040             0.0.0.0:0               LISTENING   5920
TCP   0.0.0.0:49664            0.0.0.0:0               LISTENING   984
TCP   0.0.0.0:49665            0.0.0.0:0               LISTENING   816
TCP   0.0.0.0:49666            0.0.0.0:0               LISTENING   1936
TCP   0.0.0.0:49667            0.0.0.0:0               LISTENING   3040
TCP   0.0.0.0:49668            0.0.0.0:0               LISTENING   4404
TCP   0.0.0.0:49670            0.0.0.0:0               LISTENING   956
TCP   0.0.0.0:57497            0.0.0.0:0               LISTENING   12764
TCP   127.0.0.1:1001           0.0.0.0:0               LISTENING   4
TCP   127.0.0.1:4709           0.0.0.0:0               LISTENING   12764
TCP   127.0.0.1:9050           0.0.0.0:0               LISTENING   1592
TCP   127.0.0.1:58137          127.0.0.1:58138          ESTABLISHED 1592
TCP   127.0.0.1:58138          127.0.0.1:58137          ESTABLISHED 1592
TCP   127.0.0.1:62532          0.0.0.0:0               LISTENING   13588
TCP   127.0.0.1:64031          127.0.0.1:64032          ESTABLISHED 1592
TCP   127.0.0.1:64032          127.0.0.1:64031          ESTABLISHED 1592
```

Command Prompt

C:\Users\ara81>tasklist /v

Image Name	PID	Session Name	Session#	Mem Usage	Status	User Name
	CPU	Time Window Title				
System Idle Process	0	Services	0	8 K	Unknown	NT AUTHORITY\SYSTEM
System	0:49:04	N/A	0	3,756 K	Unknown	N/A
Secure System	0:02:55	N/A	0	54,912 K	Unknown	N/A
Registry	68	Services	0	57,724 K	Unknown	N/A
smss.exe	0:00:00	N/A	0	1,700 K	Unknown	N/A
csrss.exe	524	Services	0	6,844 K	Unknown	N/A
wininit.exe	728	Services	0	9,544 K	Unknown	N/A
csrss.exe	0:00:01	N/A	0	8,020 K	Unknown	N/A
winlogon.exe	816	Services	0	17,972 K	Unknown	N/A
services.exe	0:00:00	N/A	1	12,912 K	Unknown	N/A
LsaIso.exe	824	Console	0	4,432 K	Unknown	N/A
lsass.exe	0:00:11	N/A	0	36,508 K	Unknown	N/A
	976	Services	0			
	0:00:00	N/A	0			
	984	Services	0			

Step 3: Disk Imaging (Post-Mortem Acquisition)

After all volatile evidence has been preserved, the compromised system should be **isolated from the network** to prevent further attacker activity.

Action:

- Use forensic imaging tools such as **FTK Imager** or **Guymager**.
- Create a complete forensic image of the storage device in **E01 (Expert Witness Format)** or **DD (Raw Image)** format.

Evidence Integrity (Most Important)

Once the forensic image has been created, investigators must calculate its cryptographic hash value (such as **MD5** or **SHA-256**).

The hash serves as a digital fingerprint of the evidence.

During a court proceeding or forensic investigation, the original hash value is compared with the current hash value. If both values match, it proves that the evidence has remained unchanged and maintains its integrity throughout the investigation.

Sigma Rules and YARA Rule Development

This is one of the most interesting and technical sections of the task: creating **Sigma Rules** and a **YARA Rule**.

Before writing the rules, it is important to understand the difference between them:

Sigma Rule

A **Sigma Rule** is used to detect suspicious activity in logs such as Windows Event Logs, Syslog, or SIEM platforms. It defines patterns that generate alerts when suspicious commands or behaviors are observed.

YARA Rule

A **YARA Rule** is used to detect malware, malicious files, or suspicious memory artifacts. It searches for specific strings, byte patterns, or indicators within files and memory.

Based on the scenario, the following **five Sigma Rules** and **one YARA Rule** have been designed.

1. Sigma Detection Rules

Rule 1: Detect Windows Event Log Clearance

Target Phase: Impact / Anti-Forensics

Logic: Detects attempts to clear Windows Event Logs using the wevtutil command, a common anti-forensic technique used by attackers to remove evidence.

title: Detect Windows Event Log Clearance

id: 11111111-2222-3333-4444-555555555555

status: experimental

description: Detects the clearing of Windows event logs using wevtutil, which is a common anti-forensics technique.

author: Intern (Allied Software Engineers)

date: 2026/07/13

logsource:

product: windows

service: security

detection:

selection:

EventID: 4688

NewProcessName|endswith: '\wevtutil.exe'

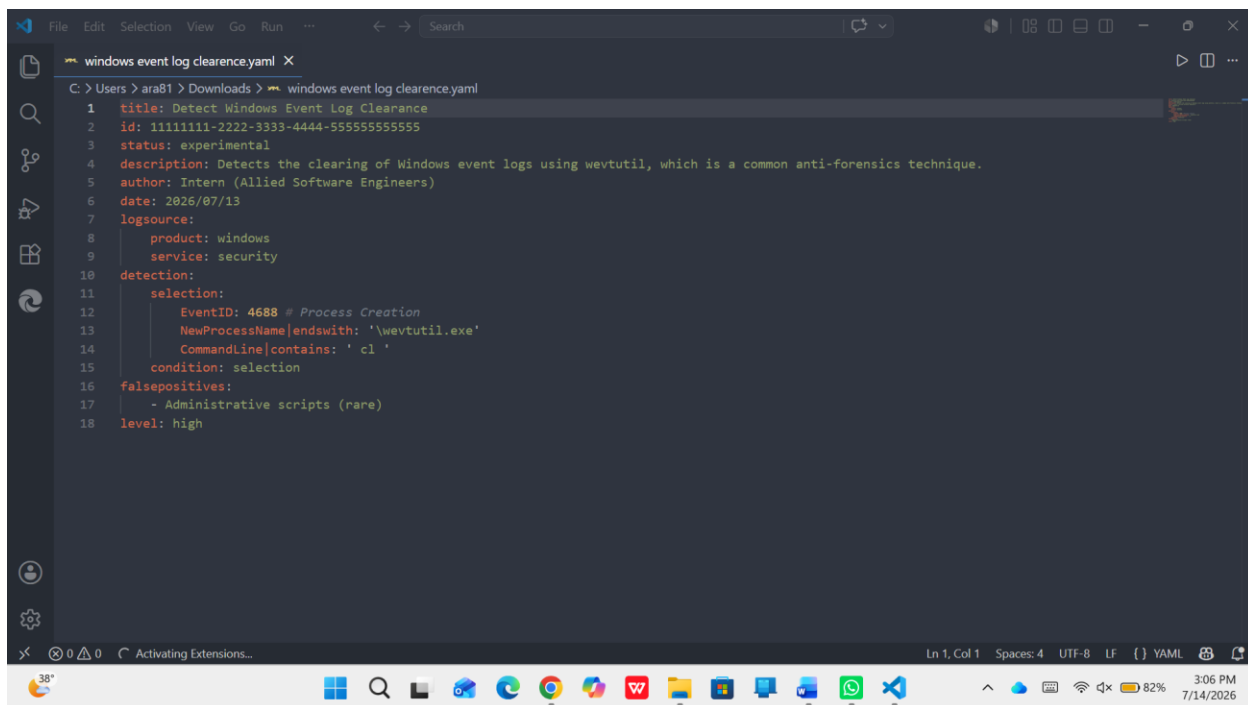
CommandLine|contains: ' cl '

condition: selection

falsepositives:

- Administrative scripts (rare)

level: high



```
1 title: Detect Windows Event Log Clearance
2 id: 11111111-2222-3333-4444-555555555555
3 status: experimental
4 description: Detects the clearing of Windows event logs using wevtutil, which is a common anti-forensics technique.
5 author: Intern (Allied Software Engineers)
6 date: 2026/07/13
7 logsource:
8   product: windows
9   service: security
10 detection:
11   selection:
12     EventID: 4688 # Process Creation
13     NewProcessName|endsWith: '\\wevtutil.exe'
14     CommandLine|contains: 'cl '
15   condition: selection
16 falsepositives:
17   - Administrative scripts (rare)
18 level: high
```

Rule 2: Detect LSASS Memory Dumping

Target Phase: Credential Access

Logic: Detects attempts to dump LSASS memory using tools such as ProcDump or Mimikatz to steal credentials.

title: Detect LSASS Process Memory Dumping

id: 22222222-3333-4444-5555-666666666666

status: experimental

description: Detects process creation patterns targeting LSASS memory to extract credentials.

logsource:

product: windows

category: process_creation

detection:

selection:

CommandLine|contains:

- 'procdump'

- 'lsass'

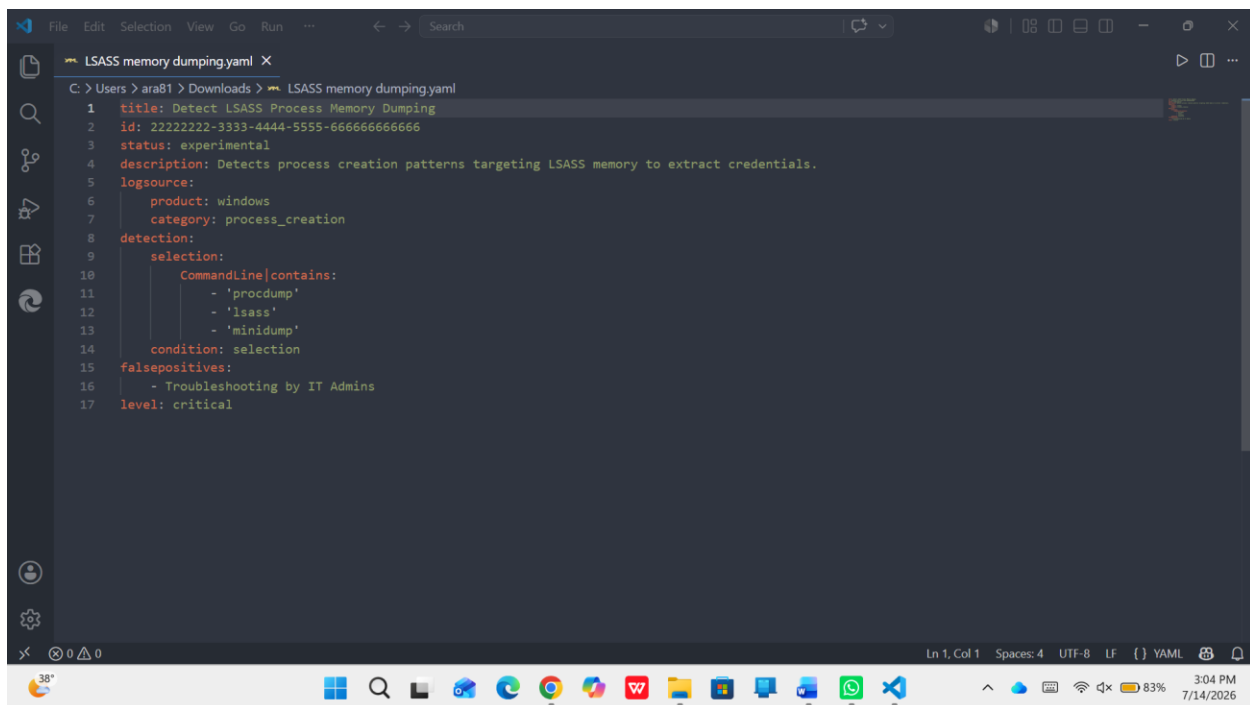
- 'minidump'

condition: selection

falsepositives:

- Troubleshooting by IT Admins

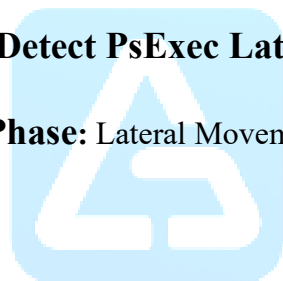
level: critical



```
1 title: Detect LSASS Process Memory Dumping
2 id: 22222222-3333-4444-5555-666666666666
3 status: experimental
4 description: Detects process creation patterns targeting LSASS memory to extract credentials.
5 logsource:
6   product: windows
7   category: process_creation
8 detection:
9   selection:
10    CommandLine|contains:
11      - 'procdump'
12      - 'lsass'
13      - 'minidump'
14    condition: selection
15 falsepositives:
16   - Troubleshooting by IT Admins
17 level: critical
```

Rule 3: Detect PsExec Lateral Movement Activity

Target Phase: Lateral Movement



ALLIED
SOFTWARE
ENGINEERS

Logic: Detects the use of PsExec, a common tool used by attackers to move laterally between systems in a Windows environment.

title: Detect PsExec Lateral Movement Activity

id: 33333333-4444-4555-6666-777777777777

logsource:

product: windows

category: process_creation

detection:

selection:

Image|endswith: '\psexec.exe'

selection_cmd:

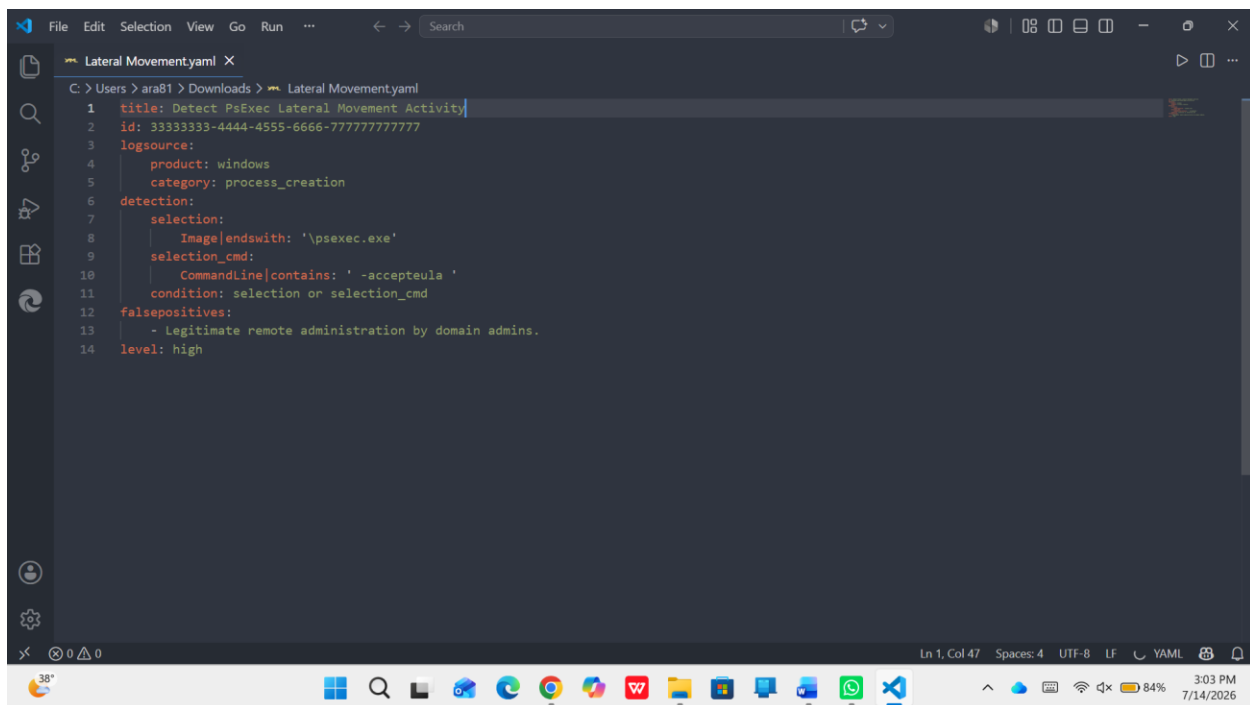
CommandLine|contains: '-accepteula '

condition: selection or selection_cmd

falsepositives:

- Legitimate remote administration by domain admins.

level: high



```
1 title: Detect PsExec Lateral Movement Activity
2 id: 33333333-4444-4555-6666-777777777777
3 logsource:
4   product: windows
5   category: process_creation
6 detection:
7   selection:
8     Image|endswith: '\\psexec.exe'
9   selection_cmd:
10    CommandLine|contains: '-accepteula '
11    condition: selection or selection_cmd
12 falsepositives:
13   - Legitimate remote administration by domain admins.
14 level: high
```

Rule 4: Detect Data Exfiltration via Cloud Storage Tools

Target Phase: Exfiltration

Logic: Detects cloud-storage utilities commonly used by attackers to upload stolen data to external services.

title: Data Exfiltration via Cloud Storage Tools

id: 44444444-5555-6666-7777-888888888888

logsource:

product: windows

category: process_creation

detection:

selection:

CommandLine|contains:

- 'rclone'

- 'mega.nz'

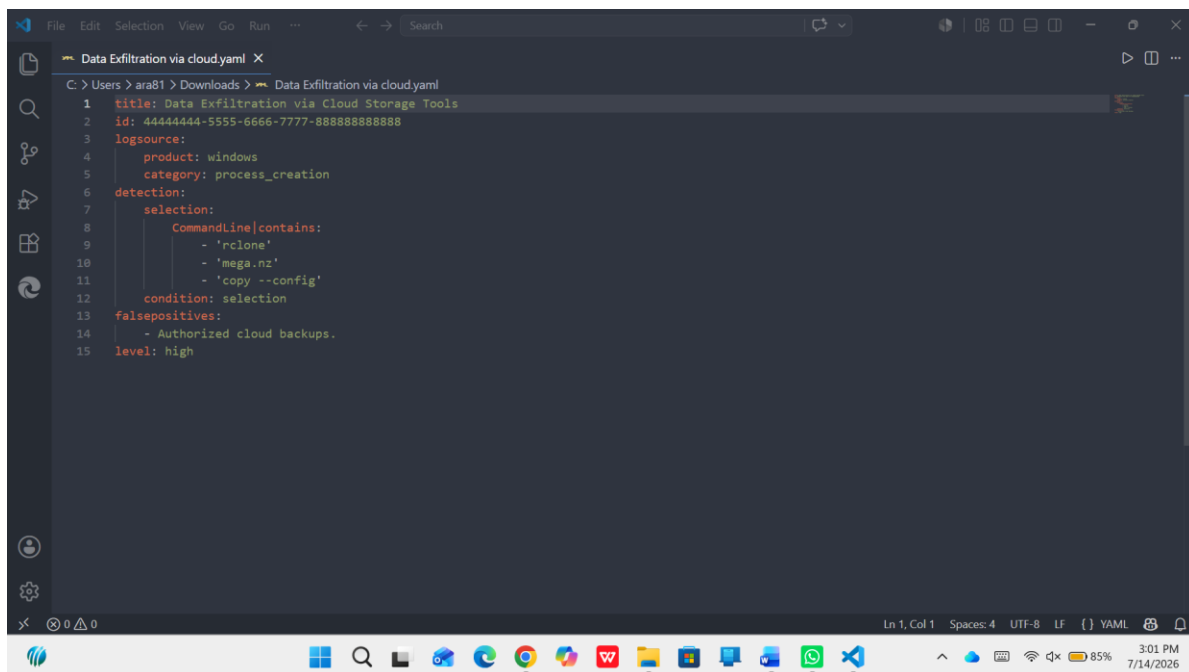
- 'copy --config'

condition: selection

falsepositives:

- Authorized cloud backups.

level: high



The screenshot shows a Windows File Explorer window with the address bar displaying 'C:\Users\ara81\Downloads\Data Exfiltration via cloud.yaml'. The file is open in a text editor, showing a YAML configuration for a security rule. The rule is titled 'Data Exfiltration via Cloud Storage Tools' and has an ID of '44444444-5555-6666-7777-888888888888'. It is categorized as 'process_creation' and has a 'logsources' field. The 'detection' section includes a 'selection' rule that checks if the 'CommandLine' contains 'rclone', 'mega.nz', or 'copy --config'. The 'condition' is set to 'selection'. The 'falsepositives' section lists '- Authorized cloud backups.' and the 'level' is set to 'high'.

```
1 title: Data Exfiltration via Cloud Storage Tools
2 id: 44444444-5555-6666-7777-888888888888
3 logsource:
4   product: windows
5   category: process_creation
6 detection:
7   selection:
8     CommandLine|contains:
9       - 'rclone'
10      - 'mega.nz'
11      - 'copy --config'
12   condition: selection
13 falsepositives:
14   - Authorized cloud backups.
15 level: high
```

Rule 5: Detect UAC Bypass via Fodhelper Registry Modification

Target Phase: Privilege Escalation

Logic: Detects registry modifications associated with the well-known **Fodhelper UAC Bypass** technique used to gain elevated privileges.

title: UAC Bypass via Fodhelper Registry Modification

id: 55555555-6666-7777-8888-999999999999

logsource:

product: windows

category: registry_event

detection:

selection:

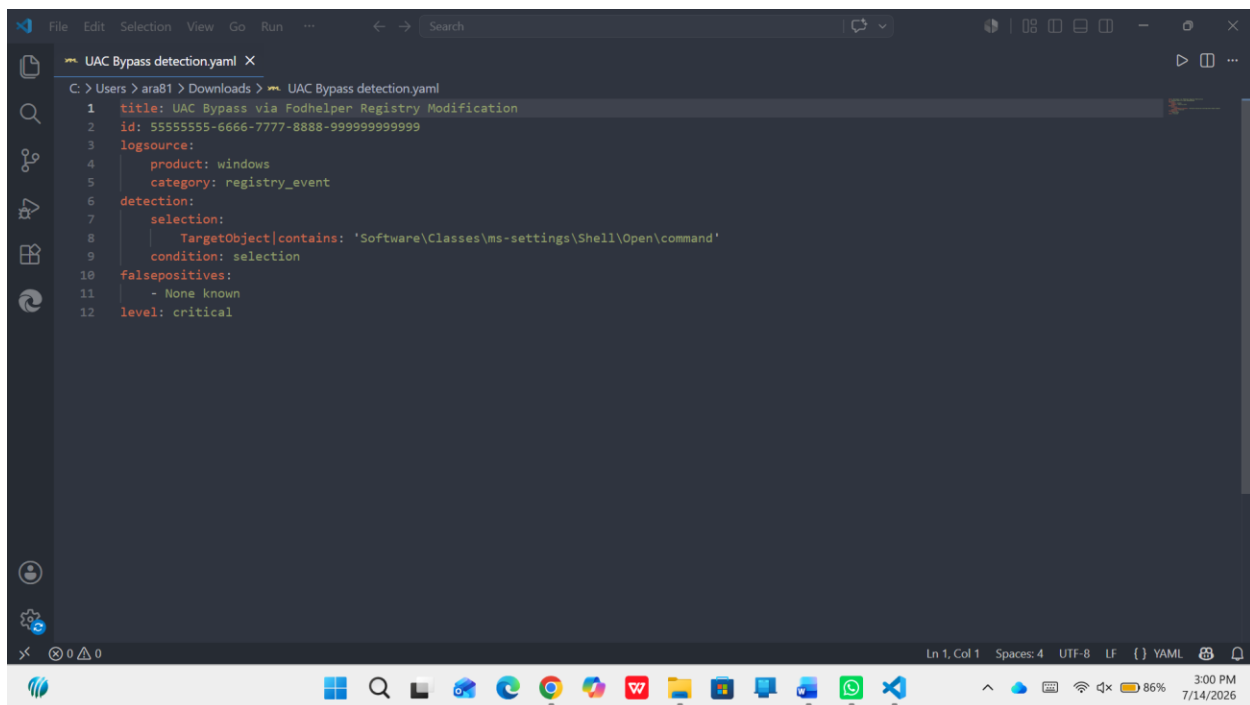
TargetObject|contains: 'Software\Classes\ms-settings\Shell\Open\command'

condition: selection

falsepositives:

- None known

level: critical



```
1 title: UAC Bypass via Fodhelper Registry Modification
2 id: 55555555-6666-7777-8888-999999999999
3 logsource:
4   product: windows
5   category: registry_event
6 detection:
7   selection:
8     TargetObject|contains: 'Software\Classes\ms-settings\Shell\Open\command'
9   condition: selection
10 falsepositives:
11   - None known
12 level: critical
```

2. YARA Rule

The following YARA rule is designed to detect a ransomware or malicious executable used during the attack. It searches for common ransomware-related strings and validates that the file is a Windows executable.

Detect Generic Ransomware Behavior

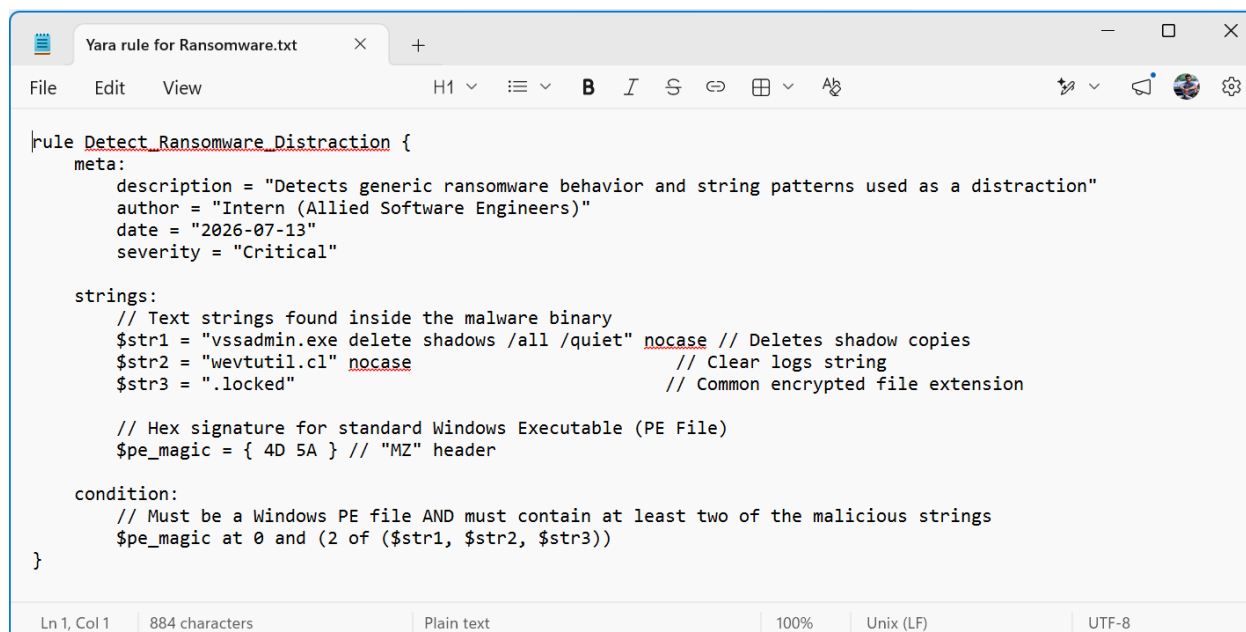
```
rule Detect_Ransomware_Distracton
{
    meta:
        description = "Detects generic ransomware behavior and string patterns used as a
        distraction"
        author = "Intern (Allied Software Engineers)"
        date = "2026-07-13"
        severity = "Critical"

    strings:
        // Strings commonly found in ransomware samples

        $str1 = "vssadmin.exe delete shadows /all /quiet" nocase
        $str2 = "wevtutil.cl" nocase
        $str3 = ".locked"

        // Standard PE executable header ("MZ")
        $pe_magic = { 4D 5A }

    condition:
        $pe_magic at 0 and (2 of ($str1, $str2, $str3))
```



```
rule Detect_Ransomware_Distraction {
  meta:
    description = "Detects generic ransomware behavior and string patterns used as a distraction"
    author = "Intern (Allied Software Engineers)"
    date = "2026-07-13"
    severity = "Critical"

  strings:
    // Text strings found inside the malware binary
    $str1 = "vssadmin.exe delete shadows /all /quiet" nocase // Deletes shadow copies
    $str2 = "wevtutil.cl" nocase // Clear logs string
    $str3 = ".locked" // Common encrypted file extension

    // Hex signature for standard Windows Executable (PE File)
    $pe_magic = { 4D 5A } // "MZ" header

  condition:
    // Must be a Windows PE file AND must contain at least two of the malicious strings
    $pe_magic at 0 and (2 of ($str1, $str2, $str3))
}
```

YARA Rule Logic

- **vssadmin.exe delete shadows /all /quiet** is commonly used by ransomware to delete Volume Shadow Copies and prevent file recovery.
- **wevtutil.cl** indicates an attempt to clear Windows Event Logs.
- **.locked** is a common extension used by ransomware to mark encrypted files.
- **4D 5A (MZ Header)** confirms that the scanned file is a Windows Portable Executable (PE) file.
- The rule triggers only when the file is a valid PE executable and contains at least **two malicious indicators**, reducing false positives.

This rule provides coverage for multiple stages of the attack lifecycle, including **Privilege Escalation, Credential Access, Lateral Movement, Data Exfiltration, Anti-Forensics, and Ransomware Deployment**, making it suitable for security monitoring and incident response activities

Threat Hunting Using Splunk SPL and Azure Sentinel KQL

In this section, we will write **Splunk SPL (Search Processing Language)** and **Microsoft Azure Sentinel KQL (Kusto Query Language)** queries to hunt for security events related to the attack scenario.

Based on the scenario, we will focus on detecting three major attacker activities:

- **Privilege Escalation**
- **Lateral Movement**
- **Data Exfiltration**

1. Privilege Escalation (UAC Bypass Detection)

In the scenario, the attacker attempted to gain administrative privileges by modifying registry keys associated with the **Fodhelper UAC Bypass** technique.

Splunk SPL

```
index=windows sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"
EventCode=13

| search TargetObject="*\\Software\\Classes\\ms-settings\\Shell\\Open\\command"

| stats count by host, User, TargetObject, Details
```

Logic:

Sysmon **Event ID 13** records registry value modifications. This query searches for changes to the registry path commonly used by the **Fodhelper UAC Bypass** technique, allowing analysts to detect potential privilege escalation attempts.

Azure Sentinel KQL

```
DeviceRegistryEvents
```

```
| where RegistryKey has @"Software\Classes\ms-settings\Shell\Open\command"
```

```
| project TimeGenerated, DeviceName, InitiatingProcessAccountName, RegistryKey,  
RegistryValueData
```

2. Lateral Movement (PsExec Activity Detection)

In the scenario, the attacker used **PsExec** to move laterally across the Active Directory environment and execute commands on remote systems.

Splunk SPL

```
index=windows sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"
```

```
EventCode=1
```

```
| search Image="*\psexec.exe" OR CommandLine="* -accepteula *"
```

```
| table _time, host, User, Image, CommandLine
```

Logic:

Sysmon **Event ID 1** records newly created processes. PsExec commonly includes the -**accepteula** command-line argument during execution, making it a reliable indicator of PsExec activity.

Azure Sentinel KQL

```
DeviceProcessEvents
```

```
| where ProcessCommandLine has "-accepteula" or FileName =~ "psexec.exe"
```

```
| project TimeGenerated, DeviceName, AccountName, FileName, ProcessCommandLine
```

3. Data Exfiltration (Cloud Storage Upload Detection)

In the scenario, the attacker exfiltrated sensitive organizational data to cloud storage using **Rclone** or similar cloud synchronization tools.

Splunk SPL

```
index=windows sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"
```

```
EventCode=1
```

```
| search CommandLine="*rclone*" AND (CommandLine="*copy*" OR  
CommandLine="*sync*")
```

```
| table _time, host, User, CommandLine
```

Logic:

Sysmon **Event ID 1** captures process creation events. This query detects execution of **Rclone** commands used to copy or synchronize files to external cloud storage services, which may indicate data exfiltration.

Azure Sentinel KQL

```
DeviceProcessEvents
```

```
| where ProcessCommandLine has "rclone"
```

```
| where ProcessCommandLine has "copy" or ProcessCommandLine has "sync"
```

```
| project TimeGenerated, DeviceName, AccountName, ProcessCommandLine
```

These threat hunting queries enable security analysts to detect critical attack activities across different stages of the cyber attack lifecycle. Specifically, they help identify:

- **Privilege Escalation** through unauthorized registry modifications used in UAC bypass techniques.
- **Lateral Movement** through PsExec execution within an Active Directory environment.
- **Data Exfiltration** through cloud synchronization tools such as Rclone used to transfer sensitive data outside the organization.

Together, these queries support proactive threat hunting, incident detection, and forensic investigations within **Splunk Enterprise Security** and **Microsoft Azure Sentinel (Microsoft Sentinel)** environments.

Host-Based and Network-Based Indicators of Compromise (IoCs) with Detection Methodology

After a cybersecurity incident occurs, a forensic investigation identifies various **Indicators of Compromise (IoCs)** that confirm the presence and activities of an attacker within the environment. These indicators help investigators detect compromised systems, trace attacker behavior, and support incident response.

IoCs are generally divided into two major categories:

- **Host-Based IoCs:** Indicators found on the compromised endpoint or computer, such as malicious files, registry changes, process execution, and file hashes.
- **Network-Based IoCs:** Indicators observed in network traffic, including malicious IP addresses, domains, DNS requests, and unusual communication patterns.

1. Host-Based IoCs and Detection Methodology

The following host-based artifacts should be examined during the forensic investigation.

IoC Type	Specific Artifact / Value (Scenario-Based)	Detection Methodology
File Hash (SHA-256)	e3b0c44298fc1c149afb4c 8996fb92427ae41e4649b9 34ca495991b7852b855 (Example ransomware hash)	Compare the hash against baseline images and scan systems using YARA rules or an Endpoint Detection and Response (EDR) platform to identify or block matching files across the network.
Registry Key	HKLM\Software\Classes\ ms- settings\Shell\Open\comm and	Monitor Sysmon Event ID 13 (Registry Events) to detect unauthorized modifications to this registry path, which is commonly abused in Fodhelper UAC Bypass attacks.
Process Names	fodhelper.exe, psexec.exe, rclone.exe	Review Windows Security Event ID 4688 or Sysmon Event ID 1 (Process Creation) to identify suspicious execution of these processes, particularly when launched by unexpected users or during unusual hours.
Directories / File Paths	C:\Users\Public\ and C:\Windows\Temp\	Attackers frequently store malicious tools and scripts in temporary or publicly accessible directories. Monitor these locations using File Integrity Monitoring (FIM) solutions and inspect Scheduled Tasks for suspicious activity.

2. Network-Based IoCs and Detection Methodology

The following network-based indicators should be monitored using firewall, proxy, DNS, and network monitoring logs.

IoC Type	Specific Artifact / Value (Scenario-Based)	Detection Methodology
----------	---	-----------------------

Malicious IP Address	185.220.101[.]5 (Example Command-and-Control Server)	Analyze Firewall Logs and NetFlow data to identify internal hosts communicating with this external IP address. Such outbound connections may indicate Command-and-Control (C2) communication.
Domain Names	mega.co.nz (used for data exfiltration), phishing-login-portal[.]com	Review DNS Logs (e.g., Sysmon Event ID 22) to identify repeated DNS queries to cloud storage services or newly observed, uncategorized domains. Frequent queries may indicate phishing activity or data exfiltration.
User-Agent String	rclone/v1.62.2 or other unusual browser identifiers	Inspect Web Proxy Logs or use Network Detection and Response (NDR) tools to analyze HTTP request headers. Suspicious or uncommon User-Agent strings may reveal automated scripts or data exfiltration tools such as Rclone.

Containment, Eradication, Recovery, and Enterprise Hardening (Based on NIST SP 800-61 Rev. 2)

When ransomware is actively encrypting systems and sensitive data is being exfiltrated, the objective is not only to detect the attack but also to contain it quickly, eliminate the threat, restore business operations, and strengthen the organization's security posture to prevent future incidents.

According to **NIST SP 800-61 Revision 2**, the incident response process can be divided into four key phases:

- **Containment**

- **Eradication**
 - **Recovery**
 - **Enterprise Hardening**
-

1. Containment

The primary objective of containment is to prevent the attack from spreading further and to stop additional lateral movement within the network.

Short-Term Containment

Network Isolation

Immediately isolate all systems showing ransomware activity or other suspicious behavior by disconnecting them from the network or placing them in a separate VLAN.

Note: The affected systems should **not** be powered off immediately because doing so would destroy valuable volatile evidence stored in RAM.

Block Malicious IP Addresses and Domains

Update enterprise firewalls, web proxies, and DNS filtering solutions to block all known attacker command-and-control (C2) IP addresses and malicious domains used for phishing or data exfiltration (e.g., **mega.nz**).

Long-Term Containment

Disable Compromised Accounts

Temporarily disable all compromised user and administrator accounts in **Active Directory**, especially those whose credentials may have been exposed through credential dumping attacks.

Strengthen Internal Firewall Rules

Restrict communication between internal network segments by tightening firewall policies and limiting access to services such as:

- SMB (TCP Port 445)
- Remote Desktop Protocol (TCP Port 3389)

This helps prevent attackers from moving laterally across the enterprise network.

2. Eradication

Once the attack has been contained, all traces of the attacker and malicious software must be completely removed from the environment.

Malware and Ransomware Removal

Perform a full enterprise-wide scan using **Endpoint Detection and Response (EDR)** or enterprise antivirus solutions to detect and remove ransomware binaries, malicious scripts, and other malware.

Remove Persistence Mechanisms

Identify and remove all persistence mechanisms established by the attacker, including:

- Registry Run Keys
- Scheduled Tasks
- Startup Folder entries
- Malicious services

These can be removed manually or through centralized Group Policy management.

Credential Revocation

Reset the **KRBtgt** account password in Active Directory **twice**, following Microsoft's recommended procedure, to invalidate any forged **Kerberos Golden Tickets**.

Additionally:

- Reset passwords for all affected user accounts.
 - Rotate privileged account credentials.
 - Revoke compromised authentication tokens and sessions.
-

3. Recovery

The recovery phase focuses on restoring normal business operations while ensuring that compromised systems are safe to return to production.

Restore from Clean Backups

Completely reimage compromised systems using trusted golden images or restore business data from verified offline backups that were not affected by the ransomware attack.

Continuous Monitoring

Monitor restored systems continuously for at least **48 to 72 hours** by reviewing:

- Security logs
- Endpoint telemetry
- Network traffic
- EDR alerts

This ensures that the attacker has been fully removed and that ransomware does not reappear.

4. Enterprise Hardening

Enterprise hardening strengthens the organization's security posture and reduces the likelihood of similar attacks occurring in the future.

Implement Microsoft LAPS (Local Administrator Password Solution)

Deploy **Microsoft LAPS** so that every workstation has a unique, automatically managed local administrator password. This significantly limits lateral movement if a single endpoint is compromised.

Deploy Endpoint Detection and Response (EDR)

Replace traditional signature-based antivirus solutions with modern **Endpoint Detection and Response (EDR)** platforms capable of detecting and blocking suspicious behaviors such as:

- LSASS memory dumping
- Registry modification
- Privilege escalation
- Ransomware execution
- Credential theft

Network Segmentation

Implement **network segmentation** or **micro-segmentation** to separate departments such as:

- Human Resources (HR)
- Information Technology (IT)
- Finance
- Production

Restrict communication between these network zones so that systems communicate only when required for business operations.

Harden Email Security

Strengthen the organization's email security gateway by enforcing:

- **SPF (Sender Policy Framework)**
- **DKIM (DomainKeys Identified Mail)**

- **DMARC (Domain-based Message Authentication, Reporting, and Conformance)**

These email authentication mechanisms help prevent email spoofing and significantly reduce the success rate of spear-phishing attacks.

